

Opportunistic encryption (OE) refers to any system that, when connecting to another system, attempts to encrypt communications channels, otherwise falling back to unencrypted communications. This method requires no pre-arrangement between the two systems.

Opportunistic encryption can be used to combat passive wiretapping. (an active wiretapper, on the other hand, can disrupt encryption negotiation to either force an unencrypted channel or perform a man-in-the-middle attack on the encrypted link.) It does not provide a strong level of security as authentication may be difficult to establish and secure communications are not mandatory. However, it does make the encryption of most Internet traffic easy to implement, which removes a significant impediment to the mass adoption of Internet traffic security.

Opportunistic encryption on the Internet is described in RFC 4322 "Opportunistic Encryption using the Internet Key Exchange (IKE)", RFC 7435 "Opportunistic Security: Some Protection Most of the Time", and in RFC 8164 "Opportunistic Security for HTTP/2".

Routers

The FreeS/WAN project was one of the early proponents of OE. The effort is continued by the former freeswan developers now working on Libreswan. Libreswan aims to support different authentication hooks for opportunistic encryption with IPsec. Version 3.16, which was released in December 2015, had support for Opportunistic IPsec using AUTH=NULL which is based on RFC 7619. The Libreswan Project is currently working on (forward) Domain Name System Security Extensions (DNSSEC) and Kerberos support for Opportunistic IPsec.

Openswan has also been ported to the OpenWrt project. Openswan used reverse DNS records to facilitate the key exchange between the systems.

It is possible to use OpenVPN and networking protocols to set up dynamic VPN links which act similar to OE for specific domains.

Linux and Unix-like systems

The FreeS/WAN and forks such as Openswan and strongSwan offer VPNs that can also operate in OE mode using IPsec-based technology. Obfuscated TCP is another method of implementing OE.

Windows OS

Microsoft Windows platforms have an implementation of OE installed by default. This method uses IPsec to secure the traffic and is a simple procedure to turn on. It is accessed via the MMC and "IP Security Policies on Local Computer" and then editing the properties to assign the "(Request Security)" policy. This will turn on optional IPsec in a Kerberos environment.

Many systems also have problems when either side is behind a NAT. This problem is addressed by NAT traversal (NAT-T) and is accomplished by editing a registry item. Using the filtering options provided in MMC, it is possible to tailor the networking to require, request or permit traffic to various domains and protocols to use encryption.

Email

Opportunistic encryption can also be used for specific traffic like e-mail using the SMTP STARTTLS extension for relaying messages across the Internet, or the Internet Message Access Protocol (IMAP) STARTTLS extension for reading e-mail. With this implementation, it is not necessary to obtain a certificate from a certificate authority, as a self-signed certificate can be used.

RFC 2595 Using TLS with IMAP, POP3 and ACAP

RFC 3207 SMTP Service Extension for Secure SMTP over TLS

STARTTLS and postfix

STARTTLS and Exchange

Many systems employ a variant with third-party add-ons to traditional email packages by first attempting to obtain an encryption key and if unsuccessful, then sending the email in the clear. PGP, $p\equiv p$, Hushmail, and Ciphire, among others can all be set up to work in this mode.

In practice, STARTTLS in SMTP is often deployed with self-signed certificates, which represents a minimal one-time task for a system administrator, and results in most email traffic being opportunistically encrypted.

VoIP

Some Voice over IP (VoIP) solutions provide for painless encryption of voice traffic when possible. Some versions of the Sipura Technology and Linksys lines of analog telephony adapters (ATA) include a hardware implementation of SRTP with the installation of a certificate from Voxilla, a VoIP information site. When the call is placed an attempt is made to use SRTP; if successful a series of tones is played into the handset; if not the call proceeds without using encryption. Skype and Amicima use only secure connections and Gizmo5 attempts a secure connection between its clients. Phil Zimmermann, Alan Johnston, and Jon Callas have proposed a new VoIP encryption protocol called ZRTP. They have an implementation of it called Zfone whose source and compiled binaries are available.

Websites

For encrypting WWW/HTTP connections, HTTPS is typically used, which requires strict encryption and has significant administrative costs, both in terms of initial setup and continued maintenance costs for the website operator. Most browsers verify the webserver's identity to make sure that an SSL certificate is signed by a trusted certificate authority and has not expired, usually requiring the website operator to manually change the certificate every one or two years. The easiest way to enable some sort of opportunistic website encryption is by using self-signed certificates, but this causes browsers to display a warning each time the

website is visited unless the user manually marks the website's certificate as trusted. Because unencrypted websites do not currently display any such warnings, the use of self-signed certificates is not well received.

In 2015, Mozilla started to roll out opportunistic encryption in Firefox version 37. This was quickly rolled back (in update 37.0.1) due to a serious vulnerability that could bypass SSL certificate verification.

Browser extensions like HTTPS Everywhere and HTTPSfinder find and automatically switch the connection to HTTPS when possible.

Several proposals were available for true, seamless opportunistic encryption of HTTP/2 protocol. These proposals were later rejected. Poul-Henning Kamp, lead developer of Varnish and a senior FreeBSD kernel developer, has criticized the IETF for following a particular political agenda with HTTP/2 for not implementing opportunistic encryption in the standard.

Weaknesses

STARTTLS implementations often used with SMTP are vulnerable to STRIPTLS attacks when subject to active wiretapping.

See also

John Gilmore

Multi-factor authentication

Opportunistic TLS

Opportunistic Wireless Encryption (OWE)

Security level

Security level management

tcpcrypt

References

External links

Enabling Email Confidentiality through the use of Opportunistic Encryption by Simson Garfinkel of the MIT Laboratory for Computer Science, May 2003

Windows KB article on NAT-T and DH2048

RFC 4322 – Opportunistic Encryption using the Internet Key Exchange (IKE)

RFC 7258 – Pervasive Monitoring Is an Attack